OPTIV CONSULTING · CYBER STRATEGY CONSULTING

Case Study 1: Complete Beginner's Master Guide

Everything Explained in Simple, Plain English · From Zero to Hero (Final Updated Edition)

> 🎯 **Quick Summary for Anyone New to This Project:**
> A large bank named **'Meridian Financial'** hires outside software and service companies (vendors) to do things like process customer accounts, send bank statements, and clear payments. Today, many tech companies are quietly adding Artificial Intelligence (like ChatGPT, OpenAI, or automated agents) into their software. If a vendor feeds real customer bank data or administrative logs into an unvetted AI without telling the bank, that is illegal, unsafe, and a massive risk! Optiv built an evidence-driven **detective system using Open Source Intelligence (OSINT)** to check whether these vendors are secretly using AI, how risky it is, and what the bank must do about it.

1. The Story: What is Happening Here?

Imagine you run a bank called **Meridian Financial**. You have over a million customers who trust you with their life savings, account balances, and personal secrets. Because running a modern bank is huge and complex, you don't build all the software yourself. You hire outside companies (known in corporate governance as **'Third-Party Vendors'**):

- **Core Banking:** One company (**Fiserv**) hosts your main computer platform where customer accounts, balances, and ledger transactions live.
- **Printing & Mailing:** Another company (**FSSI**) prints and mails monthly statements and IRS tax forms to your customers.
- **Payment Rails:** Another company (**BNY**) transmits time-critical real-time payments between financial institutions.
- **IT Support & Workload Automation:** Another company (**AutomWorx**) helps you manage automated nightly computer batch jobs.
- **National Clearing:** A systemic utility (**The Clearing House**) clears ACH and Real-Time Payments bank-wide.
- **Wealth Reporting:** Another company (**Terrapin Technologies**) aggregates data and calculates commissions for wealth advisors.

Now, imagine one of these companies quietly connects their platform to an Artificial Intelligence model (like OpenAI or Microsoft Azure) to 'speed things up' or 'summarize logs'—**WITHOUT TELLING YOU!**

Suddenly, your customers' private account numbers, balances, and names might be sent across the internet to an external AI company's servers. If that AI model leaks the data, or if government regulators (like the OCC or Federal Reserve) find out, your bank faces millions of dollars in fines and loses all customer trust!

This is the challenge. Meridian Financial's Third-Party Risk Management (TPRM) team hired Optiv Consulting to answer three core questions: *'Which of our vendors are secretly using AI? How dangerous is it to our bank? And what contractual and technical actions must we take immediately?'*

2. Important Buzzwords Explained in Plain English

TPRM:	**Third-Party Risk Management.** Checking whether the outside companies you hire are safe, trustworthy, and not mishandling your data.
OSINT:	**Open Source Intelligence.** Acting like an ethical detective by analyzing publicly available technical clues—like corporate newsrooms, API documentation, job postings, and SEC filings—to uncover facts.

PII: **Personally Identifiable Information.** Private customer data: full names, home addresses, Social Security Numbers (SSN), or bank balances.

Sub-Processor: **A vendor hired by your vendor!** For example, if Meridian hires Fiserv, and Fiserv quietly uses OpenAI to run automated agents, OpenAI is an undisclosed **4th-party sub-processor**.

Operational Dependency: How badly your bank suffers if a vendor crashes. If they go down, does your entire bank halt immediately (Critical), or is it just a slight delay (Moderate)?

3. The 4-Factor Criticality Formula (How We Score Vendors)

Before investigating whether a vendor uses AI, we first have to answer: *'How important and dangerous is this vendor to our bank?'* To ensure our score is completely objective and repeatable (so any two analysts reach the exact same answer), we created an objective **100-Point Scoring Formula** with 4 pillars:

Scoring Pillar	Max Points	Point Allocation & Scoring Logic
1. Data Sensitivity Accessed	**30 pts**	**30 pts:** Full customer master, balances, tax IDs, or hardship notes. **20 pts:** System credentials, passwords, or wealth client data. **15 pts:** Payment messages in transit only. **0 pts:** Public marketing info.
2. Operational Dependency	**30 pts**	**30 pts:** Critical / Total (The entire bank freezes immediately). **20 pts:** High (Daily payment clearing or batch schedules get degraded). **10 pts:** Moderate (Monthly statements or compensation withstand delay).
3. Payment Rail Involvement	**20 pts**	**20 pts:** Systemic national clearing network (ACH, RTP). **15 pts:** Core banking ledger holding money or live payment gateway. **5 pts:** IT batch automation schedules. **0 pts:** No payments.
4. Volume & Regulatory Exposure	**20 pts**	**20 pts:** >100 million transactions (bank-wide scale). **15 pts:** >10 million documents/messages or IRS regulatory tax filings. **10 pts:** Millions of messages. **5 pts:** Monthly wealth cycles.

The Final Tiers based on Total Score (out of 100):

- **Critical Tier (Score 80–100):** Catastrophic impact if compromised. Mandates full forensic review + vendor questionnaire.
- **High Tier (Score 60–79):** High operational dependency or administrative system access. Mandates targeted technical review.
- **Moderate / Medium Tier (Score 40–59):** Touches volume data but bank does not halt. Mandates standard OSINT check.
- **Low Tier (Score < 40):** Commodity vendor. Surface scan only to avoid wasted investigative time.

4. The Detective Strategy: Real AI vs. Marketing Hype

Almost every technology vendor publishes blogs claiming: *'We love AI! Our platform is AI-powered!'* Does that mean they are actually running LLMs on your bank's real data? **NO!** Optiv established a strict **4-Tier Evidentiary Weight System** so we never get misled by sales buzzwords:

Tier 1: Technical Truth (Weight: 0.90 to 1.00) Official sub-processor registers, API technical manuals, SEC 10-K government filings, and SOC 2 Type II system descriptions. Treated as **Pure Technical Fact**.

Tier 2: Engineering Proof (Weight: 0.70 to 0.85) Technical job postings for AI engineers (e.g. *'Must orchestrate LLMs via Model Context Protocol'*), developer whitepapers, and public code repositories. **Very Strong Proof**.

Tier 3: Executive Announcements (Weight: 0.50 to 0.65) Official corporate press releases or verified C-Suite executive announcements on LinkedIn (e.g. CEO announcing strategic AI partnerships). Needs cross-checking with technical specs.

Tier 4: Marketing Commentary (Weight: 0.10 to 0.30 - DISCOUNTED) Promotional blogs, sales brochures, or thought-leadership talking about 'the future of AI'. **DISCOUNTED!** Treated as Inconclusive or Negative for live

> production AI risk.

5. The Evaluated Vendors (Detailed Findings & Technical Reality)

V-001: AutomWorx

HIGH CRITICALITY | HIGH AI RISK | UPDATED FINDING

Category: Professional Services (Enterprise Batch Scheduling) | Target: Automic / UC4 Workload Estate

- **What they do:** AutomWorx manages automated nightly computer batch runs and workload automation across Meridian's core banking estate.
- **Why they are High Criticality:** Even though they hold no direct customer PII, they possess **root administrator credentials** and configuration access to production batch jobs.
- **Did we find AI? YES! (Technical OSINT Discovery):** Technical publications on `automworx.com/resources` confirm that Automic Automation V26 introduces native *AI Jobs*, an embedded *GenAI Automation Assistant* that queries execution logs and error traces, and a *Bring Your Own Model (BYOM)* framework using Anthropic's **Model Context Protocol (MCP)**.
- **The Real Danger:** Batch execution logs frequently contain service account passwords, API keys, and database connection strings. Ingesting these logs into external LLMs via MCP creates severe credential leakage and prompt injection risks that could disrupt overnight clearing.
- **Mandatory Action:** Issue targeted AI questionnaire within 15 business days; contractually prohibit ingesting Meridian configurations, credentials, or batch scripts into external AI models; require human review for AI-generated scripts.

V-002: Fiserv, Inc. (DNA Core Platform)

CRITICAL TIER | CRITICAL AI RISK | 🚨 THE #1 THREAT

Category: Core Platform | Scope: 1.4 Million Customers | Volume: 240 Million Transactions / Year

- **What they do:** Fiserv operates Meridian's central nervous system—the DNA core banking ledger holding full accounts, balances, and transaction history.
- **Why they are Critical:** If Fiserv suffers an outage or breach, Meridian Financial cannot function as a bank.
- **Did we find AI? YES! (Confirmed Multi-Partner Deployment):** Official press releases on `fiserv.com/newsroom` announce a major strategic collaboration with **OpenAI** deploying **'agentOS'** to run autonomous agents directly on core banking workflows. They also deploy **Microsoft Azure AI Foundry**, GitHub Copilot, and **Cognition AI (Devin)** across banking codebases.
- **The Real Danger:** 1.4 million customers' balances and master records are directly interfacing with frontier LLMs without verified zero-retention agreements or explicit customer consent. Autonomous agents could erroneously alter balances.
- **Mandatory Action:** Immediately issue formal questionnaire; demand written DPA guaranteeing zero-data-retention and zero-model-training from OpenAI and Microsoft; secure contractual right to disable autonomous agents in Meridian's tenant; escalate to CISO and Board Risk Committee.

V-003: Financial Statement Services, Inc. (FSSI)

HIGH CRITICALITY | NONE IDENTIFIED AI RISK | HYPE DEBUNKED

Category: Document & Communications (Print & Mail) | Volume: 19 Million Tax & Account Documents / Year

- **What they do:** Produces, prints, and mails monthly customer account statements and IRS regulatory tax filings.
- **Why they are High Criticality:** High data sensitivity—accesses customer names, balances, and full IRS tax identifiers (SSNs/TINs).
- **Did we find AI? NO (Marketing Buzzwords Debunked):** While marketing blogs praise AI, technical audit of their `workStreamOne` composition engine confirms it uses deterministic, rule-based formatting and automated inserters. Zero LLMs or generative AI touch production documents.
- **The Finding:** High baseline data risk (SSNs), but zero AI exposure. Classifying them as AI-active would be a costly false alarm.
- **Mandatory Action:** Maintain standard SOC 2 Type 2 / HIPAA cybersecurity oversight; insert preventative clause requiring written notice before adopting future AI text extraction.

5. The Evaluated Vendors (Continued)

V-004: Terrapin Technologies, Inc.

MEDIUM CRITICALITY | LOW AI RISK | ETL REALITY

Category: Data & Reporting (Wealth Management) | Scope: 38,000 Wealth Clients | Cycle: Monthly Batches

- **What they do:** Consolidates investment holdings and calculates commissions and compliance metrics for wealth management advisors.
- **Why they are Medium Criticality:** Monthly cycle processing; an outage causes internal reporting delays but does not halt retail banking.
- **Did we find AI? INCONCLUSIVE (Downstream ETL, Not Production LLMs):** Terrapin publishes articles on *'AI-Ready Data'*, but explicitly clarifies that its platform builds clean ETL data foundations *'whether or not the firm adopts AI'*. No evidence of proprietary LLMs operating on client compensation.
- **The Finding:** Low AI Risk. The risk is limited to potential future ingestion of wealth data into unannounced AI pilot programs.
- **Mandatory Action:** Issue inquiry during standard annual review cycle; contractually forbid using Meridian data for AI benchmarking or model fine-tuning.

V-005: BNY (Bank of New York)

CRITICAL TIER | HIGH AI RISK | REAL-TIME PAYMENTS

Category: Payments (Inbound Real-Time Payments) | Volume: 2.1 Million Live Payment Messages / Year

- **What they do:** Transmits inbound Real-Time Payments (RTP) between external financial institutions and Meridian.
- **Why they are Critical:** Instant settlement operates 24/7/365. An outage degrades bank liquidity and causes counterparty contagion.
- **Did we find AI? YES! (Agentic Payment Operations):** Corporate disclosures on `bny.com` document their proprietary AI operating system **'Eliza'** deploying autonomous digital workers for payment validations and trade exceptions, powered by **Google Cloud Gemini Enterprise** and **Microsoft Azure OpenAI**.
- **The Real Danger:** Payment messages contain counterparty account numbers and instructions. Automated AI agents could falsely block legitimate transfers or route payments improperly without human oversight.
- **Mandatory Action:** Request BNY's AI Governance Whitepaper within 30 days; verify payment message isolation from external LLM training; establish strict human-in-the-loop exception handling.

V-006: The Clearing House (TCH)

CRITICAL TIER | NONE IDENTIFIED AI RISK | DETERMINISTIC RAIL

Category: Payments Infrastructure (ACH & RTP Networks) | Volume: 14 Million Core Messages / Year

- **What they do:** National systemic utility operating the primary private-sector ACH (EPN) and Real-Time Payments (RTP) clearing rails.
- **Why they are Critical:** Systemic critical infrastructure. If TCH fails, nobody in America can clear interbank electronic funds transfers.
- **Did we find AI? NO in Core Rails (Deterministic Switching):** While TCH submitted letters to the US Treasury *advocating* that participant member banks adopt AI/ML for fraud, technical review confirms their live clearing switches run strictly on **deterministic ISO 20022 message protocol rules**. Zero generative AI touches live payment payloads.
- **The Finding:** Critical operational dependency, but **None Identified AI Risk** in transit rails.
- **Mandatory Action:** Continue standard FFIEC, SOC 1/2 Type 2, and BC/DR audit oversight; monitor network rules for future centralized AI fraud screening.

Summary Portfolio Risk Register (Final Reconciled Matrix)

ID	Vendor Name	Criticality Tier	AI Detected?	AI Security Risk	4th-Party Model Providers	Governance Milestone
V-000	Larkspur (Benchmark)	Critical	Yes	Critical	Undisclosed Foundation Models	15-Day Urgent Questionnaire
V-001	AutomWorx	High	Yes	High	Broadcom / BYOM (LLMs via MCP)	15-Day Questionnaire & Script Ban

ID	Vendor Name	Criticality Tier	AI Detected?	AI Security Risk	4th-Party Model Providers	Governance Milestone
V-002	Fiserv, Inc.	Critical	Yes	Critical	OpenAI, Microsoft Azure, Cognition	15-Day DPA & Agent Opt-Out
V-003	FSSI	High	No	None identified	None (Deterministic Rules)	Annual Contract Renewal Notice
V-004	Terrapin Technologies	Medium	Inconclusive	Low	None confirmed (ETL Pipeline)	Annual Cycle Training Restriction
V-005	BNY	Critical	Yes	High	Google Cloud (Gemini), Azure OpenAI	30-Day Eliza Governance Review
V-006	The Clearing House	Critical	No (in core)	None identified	None in transit clearing	Standard FFIEC / BC-DR Audits

6. Delivered Project Files & How to Run Them

All engagement deliverables are saved directly inside your working repository: `c:\Users\ASUS\Desktop\Case Study 1 Supporting Material`. Here is how to use each asset:

📊 Meridian_Vendor_Input.xlsx (The Official Excel Submission)

- **What it is:** The official offline Excel workbook required by Optiv and Meridian Financial.
- **What we completed:** Fully populated **Columns L through V** for all vendors (Rows 6 to 11) with verified ratings, rationales, verbatim evidence excerpts, sub-processor disclosures, and 15/30-day next steps matching the V-000 benchmark standard.
- **How to open:** Double-click the file to open in Microsoft Excel, LibreOffice, or Google Sheets.

📽️ Case_Study_1_Presentation.pptx (12-Slide Executive Presentation Deck)

- **What it is:** A professional 12-slide executive slide deck designed for the CISO and Third-Party Risk Committee.
- **What is inside:** Functional 5-stage pipeline, system architecture, 100-point rubric, 4-tier evidentiary weighting, deep-dives on Fiserv/BNY/TCH, nuanced profiles, and a 3-phase governance roadmap.
- **How to open:** Double-click to open in Microsoft PowerPoint, Keynote, or upload to Google Slides.

🌐 index.html (Interactive TPRM AI Governance Platform)

- **What it is:** A modern web application providing live interactive exploration of Meridian's vendor risk portfolio.
- **Interactive features:** KPI Command Center, Interactive Risk Matrix, Filterable Vendor Inventory with Slide-Over Dossier Drawers, 4th-Party Model Supply Chain Graph, and checkable Governance Action Tracker with local storage persistence.
- **How to run:** Double-click `index.html` directly in your file explorer. It launches immediately in your web browser!

📓 Meridian_TPRM_AI_Due_Diligence.ipynb (Jupyter / Colab Pipeline Notebook)

- **What it is:** A production-grade Python data science notebook executing the automated due diligence pipeline.
- **What is inside:** Automated Excel ingestion, 100-point scoring algorithm, depth audit, evidentiary weighting, 4th-party model concentration counter, and JSON export. All 9 code cells are pre-executed with rendered outputs!
- **How to run:** Open in VS Code, JupyterLab, or upload to Google Colab (`colab.research.google.com`).

7. Hidden Systemic Risk: The 4th-Party Model Concentration

A central discovery of our engagement is that Meridian faces an invisible **4th-Party Supply Chain Concentration**:

- At the surface level (Tier 3), Meridian hires distinct companies: Fiserv (Core), BNY (Payments), and AutomWorx (Batch IT).
- Beneath the surface (Tier 4), **all three vendors funnel into the same small group of model providers: OpenAI and Microsoft Azure**.
- **The Board-Level Takeaway:** An outage, policy shift, or zero-day breach at Microsoft or OpenAI creates simultaneous, systemic operational failure across Meridian's core ledger, payments, and batch scheduling!

8. How to Present as a 5-Person Team (Slide Division & Script)

When presenting this case study to an executive panel or grading committee, divide the presentation among your 5 members as follows:

Speaker	Role / Persona	Slides Assigned	Speaking Time	Core Talking Points
Speaker 1	Engagement Lead	Slides 1 & 2	~2.5 mins	Executive hook, business context, Silent AI Proliferation, TPRM blindspots.
Speaker 2	Technical Architect	Slides 3, 4, 5 & 6	~3.0 mins	5-stage pipeline, microservice architecture, 100-point rubric, 4-tier evidentiary scale.
Speaker 3	Core Banking Analyst	Slides 7 & 8	~2.5 mins	Portfolio Overview matrix, Fiserv deep-dive (agentOS, OpenAI, Azure, 1.4M PII exposure).
Speaker 4	Infrastructure Specialist	Slides 9 & 10	~3.0 mins	BNY Eliza vs TCH deterministic switch, AutomWorx MCP log risks, FSSI & Terrapin nuance.
Speaker 5	Governance Lead & Demo	Slides 11, 12 + Web UI	~3.5 mins	3-phase governance roadmap, final checklist, and live demonstration of `index.html`.

Word-for-Word Delivery Scripts for Each Speaker

Part 1: The Context & Silent AI Proliferation — **SPEAKER 1 (SLIDES 1–2)**

"Good morning leadership. Today we present our Third-Party AI Risk and Governance Assessment for Meridian Financial. Modern banks face what we term 'Silent AI Proliferation': core vendors are embedding generative AI, LLMs, and autonomous agents into production software without formal disclosure. Traditional annual TPRM questionnaires fail to catch continuous software changes. We applied an objective, evidence-based OSINT framework to discover what vendors are genuinely doing, evaluate customer data risks, and enforce enforceable governance."

Part 2: Methodology, Scoring Rubric & Evidence Filtering — **SPEAKER 2 (SLIDES 3–6)**

"To eliminate subjective guesswork, we engineered a deterministic 100-point criticality formula across four pillars: Data Sensitivity, Operational Dependency, Payment Rail Involvement, and Volume. Crucially, criticality dictates our investigative depth—critical suppliers receive full forensic review, while low suppliers receive surface scans. Furthermore, our 4-tier evidentiary hierarchy separates verifiable technical truth (SEC filings, API guides, code repositories) from marketing collateral to eliminate false alarms."

Part 3: Portfolio Overview & The Fiserv Threat — **SPEAKER 3 (SLIDES 7–8)**

"Across Meridian's portfolio, 4 out of 7 vendors have confirmed production AI usage. Our highest priority finding is Fiserv, provider of our DNA core banking ledger holding 1.4 million customers and 240 million transactions. Fiserv officially launched 'agentOS' in strategic collaboration with OpenAI and Microsoft Azure to deploy autonomous agents across banking workflows. Meridian has zero contractual guarantees regarding tenant isolation or zero-retention from OpenAI, exposing core banking records to third-party model providers. We mandate immediate 15-day containment."

Part 4: Payment Rails & Infrastructure Nuance — **SPEAKER 4 (SLIDES 9–10)**

"In payment rails, we observed a vital contrast: BNY deploys its 'Eliza' multi-agent system powered by Gemini and Azure for real-time payment validation (High AI Risk). Conversely, The Clearing House clears 14 million ACH/RTP messages on deterministic ISO 20022 message switches with zero AI models in transit (None Identified AI Risk). Meanwhile, AutomWorx introduced a GenAI Assistant and Model Context Protocol (MCP) to parse batch logs. Because AutomWorx holds root credentials, ingesting batch streams into LLMs creates high credential-leakage risk."

Part 5: Governance Roadmap & Live Platform Demo — **SPEAKER 5 (SLIDES 11–12 + WEB UI)**

"To protect Meridian, our 3-phase roadmap executes immediate 15-day questionnaires for Fiserv and AutomWorx, updates contractual addenda with 30-day sub-processor change notices, and establishes continuous quarterly OSINT surveillance. All findings are finalized in Meridian's offline Excel workbook, our Jupyter pipeline notebook, and our working interactive web demonstration which I will now walk through live. Thank you, and our team is ready for questions!"